Semana 04 — Ver el escaneo desde el otro lado

Grupo 2 · rol Púrpura · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	04 de 10
Fase	2 — Ofensiva controlada
Grupo	2
Rol	Púrpura
Entrega	GitHub, carpeta semana_04/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Instrumenta la detección del mismo evento: activa el registro, define la alerta y mide lo que se habría visto, incluidos los falsos positivos y negativos.

- Instrumentar el evento, activando el registro que lo vería y definiendo la alerta con su umbral.
- Comparar lo que se registró con lo que se ejecutó, ítem por ítem del paso a paso.
- Reportar falsos positivos y negativos y proponer el ajuste concreto de la regla.

2 Qué aporta este rol al entregable

La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.

3 Ejemplo paso a paso

El rol Púrpura instrumenta el objetivo: captura el trafico que produce su propio escaneo, lo cuenta y lo clasifica. La pregunta no es "que puertos hay" sino "como se ve este escaneo en el registro".

3.1 Capturar el trafico durante un escaneo corto

Se captura solo la interfaz de loopback y solo los puertos del alcance. La captura se detiene sola para no crecer sin control.

```
mkdir -p semana_04/evidencia
sudo timeout 20 tcpdump -i lo -nn -w semana_04/evidencia/captura.pcap \
  'tcp and (port 8081 or port 3000 or port 2222)' &
sleep 2
nmap -sT -p 8081,3000,2222 --max-rate 20 127.0.0.1 \
  -oN semana_04/evidencia/scan.txt
wait
tcpdump -nn -r semana_04/evidencia/captura.pcap | wc -l
```

3.2 Clasificar el trafico por tecnica

Un connect completa el saludo en tres pasos; un SYN semiabierto no. Contar esos patrones es lo que permite distinguir tecnicas desde el registro.

```
tcpdump -nn -r semana_04/evidencia/captura.pcap 'tcp[tcpflags] & tcp-
    syn != 0' \
  | wc -l > semana_04/evidencia/syn.txt
tcpdump -nn -r semana_04/evidencia/captura.pcap \
  'tcp[tcpflags] & (tcp-syn|tcp-ack) == (tcp-syn|tcp-ack)' \
  | wc -l > semana_04/evidencia/synack.txt
cat semana_04/evidencia/syn.txt semana_04/evidencia/synack.txt
```

3.3 Proponer una regla de deteccion

La regla se escribe con el umbral medido, no con una intuicion. Si en la ventana se ven veinte SYNs a puertos distintos desde una sola origen, eso es un escaneo.

3.4 Comprobar que la regla no dispara con trafico normal

Se repite la captura navegando por DVWA sin escanear. Si la regla dispara, el umbral es demasiado bajo y se ajusta anotando el motivo.

3.5 Tecnica, rastro observable y deteccion

Tecnica, rastro observable y deteccion

Tecnica	Trafico observado	Rastro	Umbral	Accion
TCP connect	SYN, SYN-ACK y ACK completos	Conexion establecida en el registro	Mas de 10 en un minuto	Revisar origen
TCP SYN	SYN sin completar el saludo	Intentos sin conexion	Mas de 10 en un minuto	Alertar
UDP	Paquetes sin respuesta	ICMP port unreachable	Mas de 20 en un minuto	Correlacionar con otros eventos
Navegacion normal	Conexiones a 8081	Sesion HTTP con contenido	No aplica	Sin accion

Los conteos son de esta practica concreta; otro objetivo o otra tasa da otros numeros y eso no invalida el metodo.

4 Qué guardar en el repositorio

Se entrega la captura, los conteos por tecnica, la regla propuesta con su umbral y la prueba de que no dispara con trafico normal.

```
semana_04/
|-- informe.md
|-- escaner.py
|-- evidencia/
|   |-- captura.pcap
|   |-- scan.txt
|   |-- syn.txt
|   `-- synack.txt
`-- README.md
```

- La captura se limita a loopback y a los puertos autorizados.
- Los conteos salen de la misma captura que se entrega.
- La regla tiene umbral y accion.
- Se probo que la regla no dispara con navegacion normal.

5 Cómo se corrige

Criterio	Peso
Huella digital completa (DNS/WHOIS)	2,0
Escáner funcional con técnicas solicitadas	3,0
Comparación rigurosa contra nmap	2,5
Explicación técnica de falsos positivos y sigilo	1,5
Código con type hints, docstrings y manejo de errores	1,0
Total	**10,0**

- {'La captura puede contener credenciales de laboratorio': 'no se comparte fuera del grupo.'}
- Capturar sin limite de tiempo llena el disco; siempre con timeout.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.